

Oversight of Notification of Breach of Data Protection Security

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Notification of Breach of Data Protection Security

The Data Protection Agency has conducted 16 planned inspections focusing on the handling of breaches of data protection security by municipalities and banks. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-41-0134.

Nykredit A/S (hereinafter Nykredit) was among the companies that the Data Protection Agency selected for oversight in the autumn of 2021 following the data protection regulation[1] and the data protection act[2].

The Data Protection Agency's oversight was a written inspection that focused, among other things, on whether Nykredit had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the data protection regulation, aimed at reducing the number of breaches of data protection security involving unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information.

The inspection was announced to Nykredit by letter dated November 24, 2021, and the bank was simultaneously requested to respond to a number of questions and to submit an example of an instruction to the bank's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc.

The Data Protection Agency informed about the background for the inspection, noting that a review of the agency's cases regarding notifications of breaches of data protection security revealed that Nykredit had reported significantly more breaches of data protection security per employee in the financial institution than other financial institutions. The Data Protection Agency noted in this context that the higher number of notifications does not necessarily indicate that the bank complies with data protection regulations to a lesser extent than financial institutions that have significantly fewer notifications per employee.

By letter dated January 18, 2022, Nykredit sent a statement in which the bank responded to the Data Protection Agency's questions. Nykredit's response was also accompanied by examples of relevant instructions and guidelines.

Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of data protection security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the respective municipality's population and the number of employees in the bank.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of data protection security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of data protection security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that there appears to be the right focus on compliance with the rules among the 16 selected municipalities and banks."

Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on

whether the municipalities and banks had implemented appropriate security measures aimed at reducing the number of breaches of data protection security where unauthorized disclosure of personal data occurred in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. In this context, the data controller must ensure that all employees in the organization are, to the necessary extent, familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of data protection security.

The Data Protection Agency found on the basis of the existing material that all data controllers had implemented appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities carried out to educate employees in data protection, including to ensure that they are aware that there is no unintended disclosure of personal data to an incorrect recipient.

They have made considerations and continuously implemented both technical and organizational measures in response to past breaches of personal data security to avoid similar breaches. There is a strong focus on preventing unintended disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., and systemic initiatives, etc.

****The Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the Data Protection Regulation, including their processes for handling and recording breaches of personal data security. The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours implies that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all the data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have conducted appropriate training activities that can support compliance with the requirements in the Data Protection Regulation regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization, so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as documentation of the breaches can be carried out, including, among other things, the justification for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to concretely assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, among other things, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. The data controllers should therefore document their justifications for all significant

decisions made as a result of the breach. This applies not least if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there has been pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security. In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified in the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security. In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation to the Data Protection Authority – should also be used by the data controller to, among other things, gain an overview of what types of breaches typically occur in the organization, and based on this, consider whether there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also evident from the received consultation responses that several of the data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds on the basis of the present information that Nykredit has taken appropriate security measures in accordance with Article 32, paragraph 1, of the Data Protection Regulation, with a view to reducing the number of breaches of personal data security where unauthorized disclosure of personal data occurs, including confidential information, particularly in relation to financial information.

Below follows a more detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It is stated in Article 32, paragraph 1, of the Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing activities. of personal data. Thus, the data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks.

It is the opinion of the Data Protection Agency that the requirement in Article 32 for appropriate security will generally entail that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons, and that the data controller must, in this context, ensure that all employees in the organization are adequately familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

Nykredit has, in its statement of January 18, 2022, submitted the bank's procedures for communication with customers via email (Appendix 1), the group management's guidelines for processing personal data from May 2021 (Appendix 2), and "The Blue Folder," which is an instruction on data confidentiality (Appendix 3).

Nykredit has initially stated that the bank has a high level of data security and a robust setup to ensure that employees are aware of the efforts they must make to maintain this, and that there is ongoing

focus on ensuring that the bank has the right system solutions and processes. Employees are well-equipped to reduce the risk of data breaches and to ensure that reporting is made when breaches of personal data security occur.

In connection with considerations about the risk of unintentional disclosure of information, including confidential information, Nykredit has, among other things, stated that the bank has conducted a risk assessment for the transmission of personal data via email, including regarding appropriate encryption methods and the risk to the data subjects in relation to the nature of the transmitted information (data classification). In this context, it has been assessed when TLS encryption and end-to-end encryption should be used, respectively. Nykredit has also stated that employees are subject to strict confidentiality obligations under the Financial Business Act (§ 117), and that this responsibility is taken very seriously. Confidential information includes all information about, among others, customers and potential customers that is not publicly available, and Nykredit considers that a loss of confidentiality for such information would result in a risk to the rights and freedoms of natural persons, and such breaches will therefore always be reported to the Data Protection Agency.

Nykredit has further stated that the bank considers the number of reported breaches to be a reflection of Nykredit's particular focus on the area, including efforts to educate employees, that the business-supported process for reporting breaches is utilized by employees, and that the guidelines regarding the assessment of when to report to the Data Protection Agency are adhered to, including the assessment of breaches of the confidentiality rules in the Financial Business Act.

It appears from the mentioned procedure that customer advisors are instructed, among other things, that information such as CPR numbers must not be sent to customers via email, that they must assess the risk of sending an email and under what circumstances email can be used for customer contact.

Nykredit has stated that "The Blue Folder" – which is mandatory reading for all new employees – serves both as an instruction and a reference work. It includes, among other things, a topic on confidentiality, where it is noted what one should be aware of regarding email and encryption (confidential information must not be sent via email unless it is securely encrypted; if possible, the encryption key should be sent by a different means than the encrypted data; it must be checked that the recipient is correct and relevant; confidential information must not be sent in response to a previous email – a new email thread must be started to ensure that the recipient is correct).

Nykredit has also stated that mandatory training and education of all employees is conducted, both at the start of employment and on an ongoing basis, and that the material includes cases that focus on the risks associated with sending information to customers (auto-selection of recipient, correct recipient wrong content, data taken outside the financial institution, information sent without authorization, etc.). Employees must complete tests in the training material annually, and they must review the training material itself at least every three years. Both the process and the material are continuously updated and revised, and they are reviewed at least once a year. Employees also undergo an IT security module that includes cases regarding the prevention of phishing attempts, hacking, and similar IT security threats that can result in illegal disclosure.

It appears from the statement that Nykredit has continuously implemented technical and organizational security measures, including with a view to reducing the number of breaches of personal data security where there has been unintentional disclosure of personal data. Nykredit has, among other things, stated that an ongoing assessment of the risk of unintentional disclosure of personal data is conducted, and that a cross-functional working group has been established to support the continuous implementation of measures that can reduce the risk of breaches. The working group, which holds quarterly meetings, focuses on situations with repeated breaches of the same nature and reduction. hereof. This is done, among other things, by reviewing previous breaches and based on that, implementing targeted measures such as information campaigns, updating instructions, etc. The working group has identified that 60% of data breaches in 2020 involved unintentional disclosure. In handling specific breaches, decisions are made regarding which measures should be implemented to reduce the likelihood of similar breaches, and whether measures should be taken to ensure that there

is awareness and focus on preventing similar breaches within the relevant business unit. The cross-functional working group also collects information on measures that are being implemented in the business units.

Nykredit has listed examples of organizational measures, including training programs for employees, preventive information campaigns, departmental meetings regarding specific breaches of personal data security, reduced use of Outlook for customer dialogue, quarterly checks of data breaches, HR control of training learning, and a "Privacy Lead network," so that the local business units have a GDPR expert.

Regarding technical measures, Nykredit has enabled the use of a number of encrypted communication forms, including end-to-end encryption as an additional measure when sending emails, end-to-end encryption of the bank's mobile and online banking, mandatory TLS in Outlook, spam filtering services, secure communication through a customer system instead of Outlook, and encrypted communication to authorities and partners (TLS-secured communication channels).

Nykredit has additionally stated that the bank intends to introduce supplementary measures to further reduce the number of breaches of personal data security, where there is unintentional disclosure of personal data, including a notification function in Outlook, where employees are warned when attempting to send an email outside of Nykredit's platform, and data scanning in Outlook, where employees are warned if they intend to send an email containing CPR numbers in Outlook.

It is – notwithstanding that the Data Protection Authority has not had the opportunity to specifically assess whether all relevant employees have completed the relevant training activities, etc., and that the authority is not aware of the full content of all guidance and training materials – based on the information available, the authority's assessment is that Nykredit has taken appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, with a view to reducing the number of breaches of personal data security, where there is unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information.

In making this assessment, the Data Protection Authority has emphasized the information provided by Nykredit, including that procedures, etc., have been developed and activities have been carried out to educate employees in data protection, including to ensure they are aware that there should be no unintentional disclosure of personal data to an incorrect recipient, that Nykredit, including through the cross-functional working group, has considered and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both through business processes, ongoing guidance, etc., and systematic measures aimed at creating secure communication channels between the bank's employees and customers.

The Data Protection Authority can, upon a renewed review of the authority's cases regarding reports of breaches of personal data security, ascertain that since November 24, 2021, there has been a decrease in the number of reported breaches of personal data security from Nykredit.

However, as a number of breaches of personal data security continue to be reported, where there has been unauthorized disclosure of personal data, the Data Protection Authority recommends that Nykredit continues to focus on conducting training and awareness activities, etc., and to ensure that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Authority notes in conclusion that the authority – typically if it receives new reports of breaches of personal data security – may resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)